

DOCUMENTAÇÃO TÉCNICA · ALTERAÇÃO DOCUMENTADA

Autorização e níveis de acesso

Controle de páginas, APIs e navegação a partir da permissão persistida do usuário

Comparação: commit 2fe92e8 (HEAD) x staged files x working tree

Branch: main

Data da análise: 31 de julho de 2026

Arquivos principais: src/lib/access-levels.ts; src/lib/auth.ts; layout.tsx; usuarios/page.tsx; api/users/*; app-sidebar.tsx

Resultado: usuários autenticados acessam o painel; somente nível 1 acessa a gestão de usuários e seus endpoints.

Níveis definidos

Id	Nome	Comportamento principal
1	Administrador	dashboard com mock, item Usuários e CRUD administrativo
2	Usuário	dashboard e rastreamento reais vinculados ao CPF da conta

ACCESS_LEVELS é a fonte utilizada pela validação Zod, pelo nome gravado em USER_PERMISSION e pelo seletor da interface. isAccessLevelId rejeita valores fora de 1 e 2.

Camadas de proteção

Camada	Regra	Resposta
Layout privado	exige usuário autenticado	redirect /login
Página /usuarios	exige permission === 1	redirect /dashboard
API /api/users	exige administrador	HTTP 403
API de rastreamento	exige sessão válida	HTTP 401
Sidebar	exibe Usuários somente ao nível 1	menu filtrado no cliente com prop do servidor

Fluxo de decisão

```
cookie -> jwtVerify -> userId -> Prisma User  
sem usuário -> /login ou 401  
permission 1 -> área administrativa  
permission 2 -> dashboard/rastreamento da própria conta
```

Regras administrativas

- O administrador não pode excluir o usuário da sessão atual.
- Criar e editar sempre sincroniza o nome da permissão pela API.
- A edição da própria conta atualiza o cache local e força refresh da árvore server-side.

Pontos de atenção

- O administrador pode alterar a própria permissão para nível 2, inclusive deixando o sistema sem administrador.
- Não existe regra explícita para preservar pelo menos um administrador ativo.
- A autorização depende de valores numéricos fixos; a expansão de papéis exigirá rever comparações `permission === 1`.
- Esconder o item do menu melhora a experiência, mas a proteção efetiva continua sendo responsabilidade dos guards e APIs.